

Small Business Cybersecurity Checklist

12 things that actually move the needle.

This is the list we configure for every small business client during onboarding, in priority order. If you have 6 of these, you're ahead of most SMBs. If you have 10+, you're in better shape than a lot of mid-market companies.

Quick filter

If you store credit cards, health records, legal documents, or financial data, treat items 1-8 as non-negotiable. Item 9+ is "you should, when you can."

What we configure for every client.

- 01 Multi-factor authentication on every business account.**
Email, banking, payroll, point-of-sale admin, every SaaS tool with admin access. The single highest-impact security control. Use an authenticator app (Microsoft, Google, or 1Password) - SMS is better than nothing but app-based is meaningfully stronger.
- 02 A real password manager rolled out to your team.**
1Password Business, Bitwarden Teams, Dashlane Business. Pick one, enforce its use, kill the spreadsheet of passwords. The point isn't password complexity - it's eliminating reuse.
- 03 Automated cloud backups for every device that holds business data.**
Not "we have OneDrive." Actual versioned backup with a 30-day retention window so you can recover from ransomware that took a few days to discover. Test the restore process at least once a year.
- 04 Endpoint protection on every laptop and workstation.**
Windows Defender for Business or a similar endpoint security tool. Configured to actually update, not just installed and forgotten.
- 05 A separate guest Wi-Fi network.**
Customers, vendors, the kid working part-time - none of them need to be on the same network as your POS, your file server, or your office printer. Trivial to set up; massively reduces blast radius.
- 06 An offboarding checklist for departing employees.**
Disable accounts, revoke MFA seeds, change shared passwords, recover devices, transfer email forwarding. Most "small business breach" stories start with an old account that nobody disabled.
- 07 Phishing training for the whole team - once.**
Not a quarterly subscription, not a fear-based drip campaign. Once. A 30-minute "here's what these emails look like and what to do when you see one" session, with a simple internal protocol: when in doubt, forward to the owner.
- 08 Encryption on company laptops.**
BitLocker on Windows, FileVault on macOS. Both are free and built in. The difference between "lost laptop" and "data breach" is whether it was encrypted.
- 09 Domain DNS records configured for email (SPF, DKIM, DMARC).**
This stops bad actors from spoofing your domain to phish your customers, and it improves your own email deliverability. Set it up once, basically forever.
- 10 Admin accounts separated from daily-use accounts.**
The owner shouldn't be using a global-admin Microsoft 365 account to read email. Daily account = limited permissions. Admin tasks = a separate, MFA-protected account.
- 11 A documented incident-response basics page.**
One page. Who to call, what to do if you click a phishing link, where the backups are, who has admin access. Stick it on the office bulletin board.

12 Vendor and SaaS audit, once a year.

List every tool you pay for. Cancel the ones you don't use. For each one that touches customer data, confirm MFA is enforced and admin access is locked down. Two hours, surprising savings.

The order of operations

If you do nothing else this week, do MFA (#1) and a password manager (#2). Those two cover the entry vectors for the vast majority of small-business breaches. Then add backup (#3) within the month. Work down the list at whatever pace makes sense.

Or hand the list to us and we'll knock it out as a one-time setup engagement.

Ready to lock all this down?

Text (972) 433-9181 or visit itforbusinesssmb.com/contact